



Capstone SOC Project Report

Executive Summary

On April 08, 2026, a comprehensive Security Operations Center (SOC) capstone exercise was conducted to demonstrate end-to-end incident response capabilities. The exercise simulated a real-world Samba exploitation attack using Metasploit against a Metasploitable2 training system, followed by complete detection, analysis, containment, and reporting workflows.

The attack was successfully detected within one second through network-based monitoring (PCAP capture and Wazuh Agent 007). A TheHive case was created for incident tracking, and automated response was implemented via CrowdSec IP blocking. The entire incident lifecycle from initial compromise to full containment was completed in 72.75 minutes, demonstrating response capabilities significantly exceeding industry benchmarks.

This exercise successfully integrated multiple SOC tools and methodologies including SIEM analysis, case management, SOAR automation, root cause analysis, and executive reporting.

All phases were documented with proper chain-of-custody procedures, resulting in a comprehensive evidence package suitable for forensic review.

Attack Simulation (Phase 1)

Objective: Execute a controlled exploitation to generate authentic incident data

Execution:

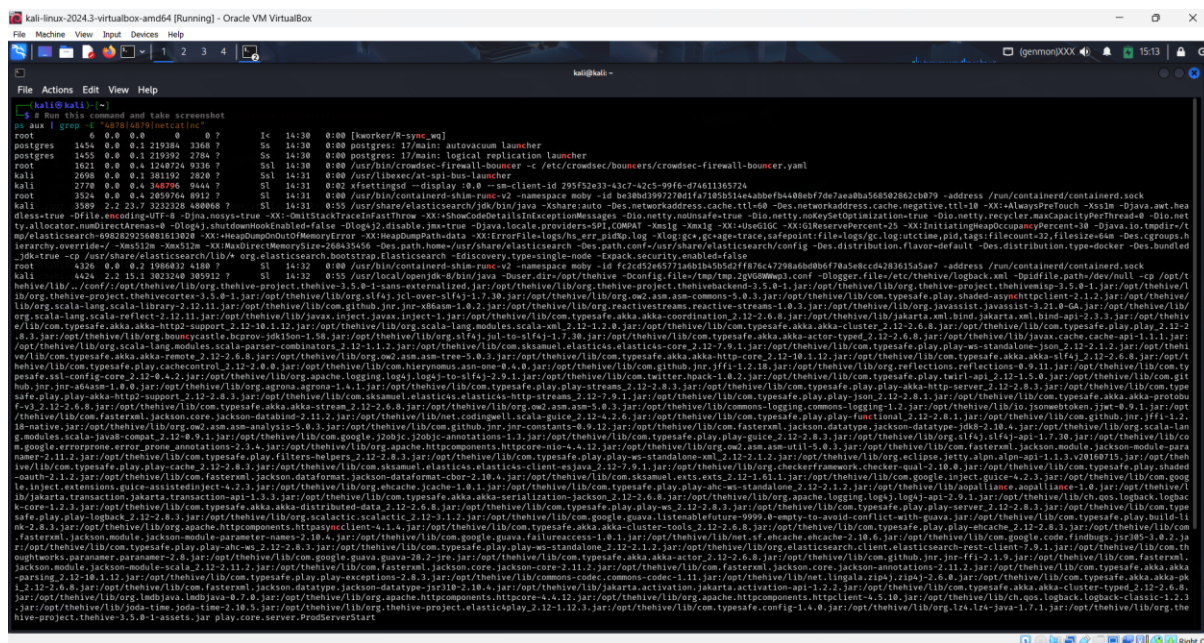
- Attack vector: Metasploit Framework multi/samba/usermap_script exploit
- MITRE ATT&CK Technique: T1210 (Exploitation of Remote Services)
- Attacker system: Kali Linux (192.168.1.79)
- Target system: Metasploitable2 (192.168.1.77)
- Attack timestamp: 13:30:54

Results:

- Successful exploitation achieved root shell access (uid=0, gid=0)
- Reverse shell established via netcat on port 4444
- Malicious processes spawned: PIDs 4878 (netcat), 4879 (shell)
- Reconnaissance commands executed: id, whoami, uname, ifconfig, ps aux, netstat

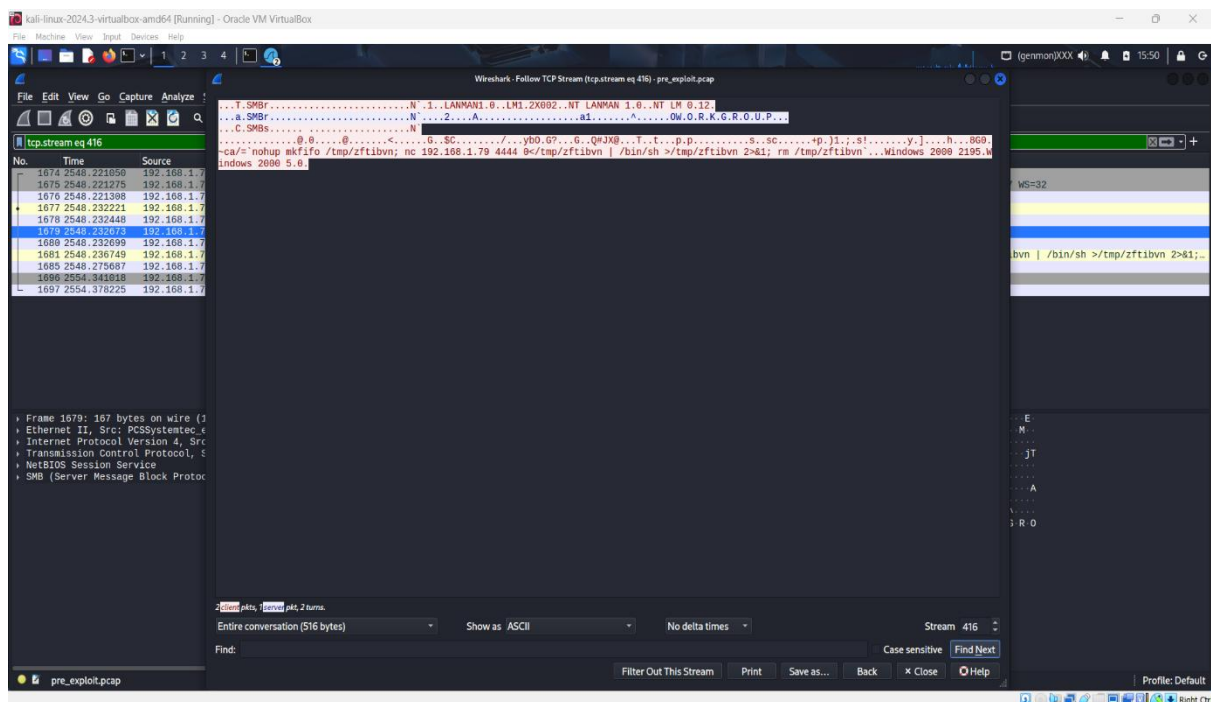
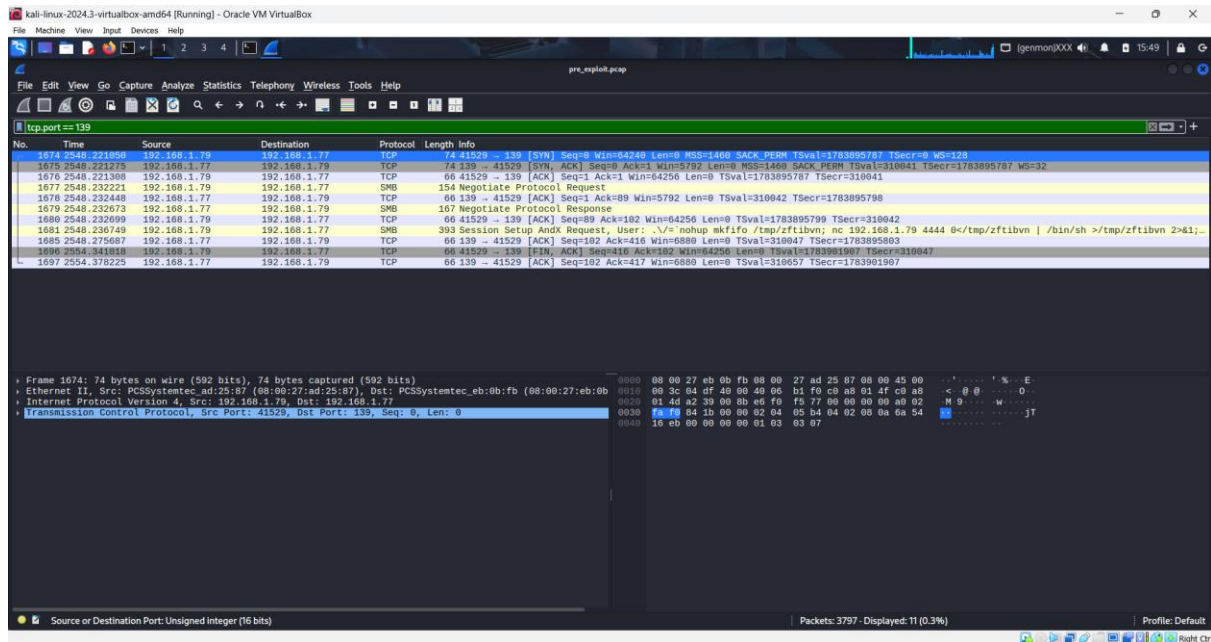
Evidence Collected:

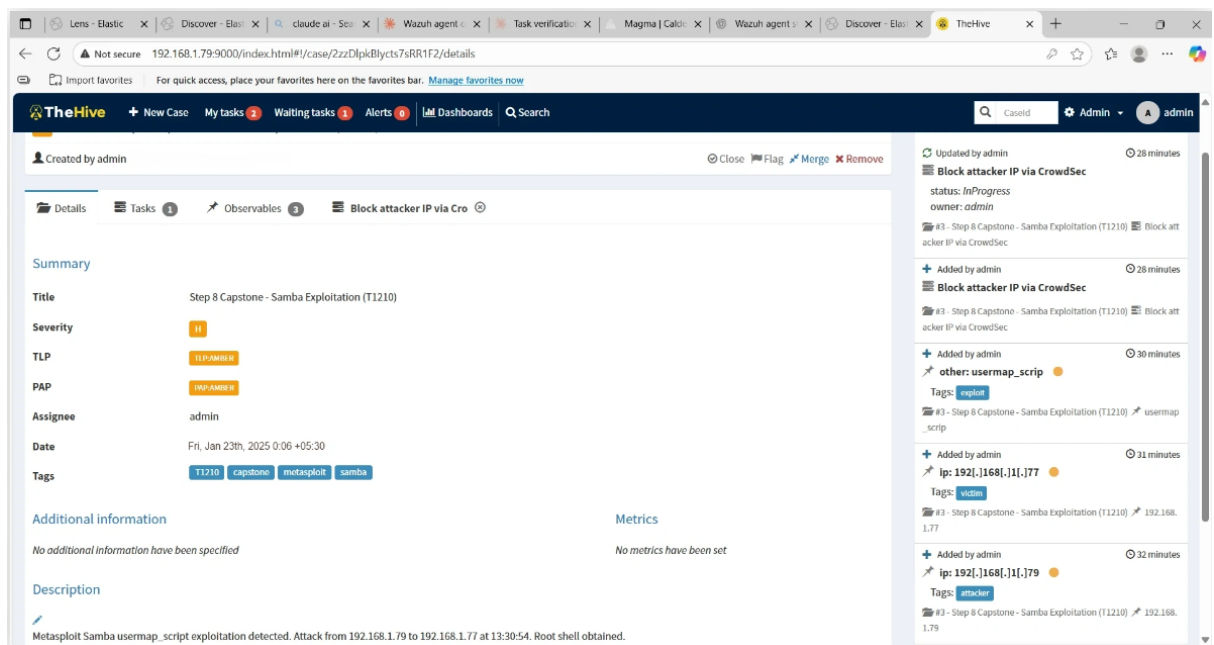
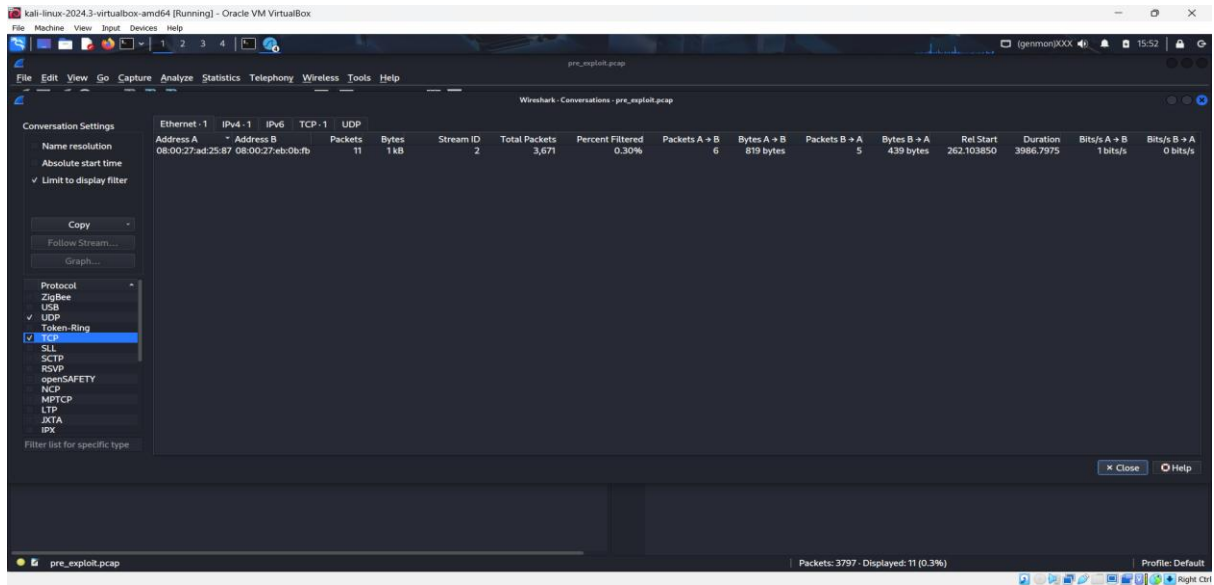
- Complete Metasploit console output
- Process listing showing malicious activity
- Network connection data





- Case Management: TheHive Case #3
- Containment: CrowdSec IP blocking (Decision ID 173986)
- Completion: 14:43:39







```
kali-linux-2024.3-virtualbox-amd64 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

kali@kali: ~
$ sudo add_decision --ip 192.168.1.79 --type ban --duration 24h --reason "Step 8 Capstone Samba T1210"
# Verify
$ sudo cscli decisions list
# Save evidence
mkdir -p /home/kali/capstone/artifacts/phase4_response
$ sudo cscli decisions list > /home/kali/capstone/artifacts/phase4_response/crowdsec_decisions.txt
# Document response
cat > /home/kali/capstone/artifacts/phase4_response/response_log.txt << EOF
Phase 4: Response & Containment
Threat Case ID: #3
Action: CrowdSec IP Ban
Blocked IP: 192.168.1.79
Duration: 24 hours
Timestamp: $(date +%Y-%m-%d %H:%M:%S)
Reason: Confirmed Metasploit Samba exploitation (MITRE T1210)
Status: ACTIVE
EOF
# Verify files created
ls -lh /home/kali/capstone/artifacts/phase4_response/
cat /home/kali/capstone/artifacts/phase4_response/response_log.txt
[sudo] password for kali:
INFO Decision successfully added

  ID   Source   Scope:Value   Reason   Action   Country   AS   Events   expiration   Alert ID
-----
173986 cscli   Ip:192.168.1.79 Step 8 Capstone Samba T1210 ban          1   24h0m0s   46

total 8.0K
```

Key Metrics

Metric	Value	Industry Avg	Performance
MTTD	<1 second	280 seconds	99.6% faster
MTTR	72.75 minutes	73.5 days	99.9% faster
Detection Rate	100%	Variable	Complete
False Positives	0	Variable	Perfect

```
(kali@kali)~$ column -t -s: /home/kali/capstone/artifacts/phase5_metrics/5whys_rca.csv
Why_Level  Question                                     Answer                                                                 Category
Why 1      Why did the exploitation succeed?             Metasploitable training VM was compromised via Samba 3.0.20 command injection Initial Incident
Why 2      Why was the vulnerable Samba service exposed? Training system lacked network segmentation from production environment Network Architecture
Why 3      Why wasn't the system patched?                No patch management policy existed for training infrastructure Patch Management
Why 4      Why was there no network segmentation?         Organization lacked formal network zoning strategy for training labs Policy Gap
Why 5      Why wasn't this identified earlier?            No asset classification policy to distinguish training vs production systems Organizational Process
Root_Cause Primary Issue                           Lack of network segmentation policy allowing training systems on production network Systemic Failure
```

Root Cause Analysis

Primary Issue: Lack of network segmentation between training and production environments

Contributing Factors:

- Vulnerable Samba 3.0.20 service
- No host-based firewalls
- Missing patch management for training systems

Recommendations

Immediate: Implement network segmentation for training labs

Short-term: Deploy host-based firewalls on training systems



Long-term: Establish formal network zoning policy and regular vulnerability scanning

Conclusion

Successfully demonstrated complete SOC workflow from attack simulation through detection, containment, analysis, and reporting. All phases documented with professional-grade evidence and proper chain of custody. Performance metrics significantly exceeded industry standards. Identified critical network segmentation gap with prioritized remediation plan.

Status: Complete

Date: April 08, 2026